

Plano de Respostas aos Riscos

Projeto: FlexHealth **Data:** 08/05/2026 **Versão:** 1.0

1. Introdução

Este documento detalha as estratégias e ações específicas planejadas para lidar com os riscos identificados no projeto **FlexHealth** — sistema baseado em microcontrolador ESP32 para monitoramento contínuo de temperatura e umidade em ambientes de armazenamento de vacinas.

O objetivo é reduzir ou eliminar as ameaças aos objetivos do projeto, especialmente aquelas que possam comprometer a integridade da cadeia de frio e a confiabilidade dos dados coletados. Este plano é complementar ao Plano de Gerenciamento de Riscos (versão 1.0) e deve ser utilizado e atualizado continuamente pela equipe ao longo do ciclo de vida do projeto.

Como complemento às análises de risco realizadas pela equipe, o projeto também passou por auditoria automatizada utilizando a plataforma Aikido Security, permitindo identificar, monitorar e mitigar vulnerabilidades relacionadas à exposição de credenciais, comunicação insegura, autenticação da API REST e dependências do frontend. As informações obtidas auxiliaram diretamente na definição das estratégias de resposta descritas neste documento.

2. Tabela de Respostas aos Riscos

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas	Responsável pela Ação	Prazo para Implementação	Status
SEG-001	Interceptação de pacotes de dados transmitidos via rede Wi-Fi entre o ESP32, o broker MQTT (HiveMQ) e o backend, permitindo espionagem das informações de monitoramento e possível mapeamento da infraestrutura do sistema	Alto	Mitigar	1. Utilizar comunicação MQTT protegida com criptografia TLS/SSL de ponta a ponta. 2. No firmware ESP32, implementar conexão segura utilizando a biblioteca <WiFiClientSecure.h>. 3. No backend Python, utilizar client.tls_set() para garantir comunicação criptografada com o broker MQTT. 4. Documentar a utilização de protocolos seguros para garantir confidencialidade e integridade dos dados em trânsito.	Rodrigo Gama / Rafaella Morelli	Antes da implantação final do sistema	Concluído

SEG-002	Exposição indevida de rotas da API, credenciais e informações sensíveis diretamente no código-fonte do Frontend e Backend (Hardcoding), permitindo que agentes maliciosos mapeiem a infraestrutura do sistema através da engenharia reversa do código.	Médio	Prevenir (Evitar)	1. Isolar endpoints de comunicação e variáveis sensíveis utilizando arquivos .env no frontend React/Vite e backend Python. 2. Impedir que credenciais sejam versionadas no repositório GitHub através da configuração adequada do .gitignore. 3. Implementar leitura segura de variáveis utilizando os.getenv() no backend Python. 4. Revisar continuamente o repositório utilizando ferramentas automatizadas de análise de segurança para identificação de credenciais expostas. 5. Reduzir exposição de informações críticas durante compilação e deploy da aplicação.	Ettore Grecco	Durante a implementação do frontend e backend	Em Andamento
----------------	--	--------------	--------------------------	--	---------------	---	--------------

SEG-003	A API Flask pode permitir acesso não autorizado aos dados do sistema devido à configuração aberta do CORS, ausência de autenticação nas rotas HTTP e execução insegura do backend em ambiente de desenvolvimento.	Alto	Mitigar	1. Restringir o CORS para aceitar requisições apenas do domínio oficial do dashboard React. 2. Implementar autenticação baseada em token JWT para proteger os endpoints da API REST. 3. Validar permissões de acesso antes da entrega dos dados ao frontend. 4. Desativar o modo debug do Flask em ambiente de produção para evitar exposição de informações internas e riscos de execução remota de código. 5. Registrar tentativas de acesso indevido para auditoria e monitoramento.	Ettore Grecco / Rodrigo Gama	Antes da publicação do dashboard	Em Andamento
SEG-004	Um agente malicioso pode publicar mensagens falsas no tópico MQTT do sistema, simulando eventos críticos ou alterando informações monitoradas, comprometendo a integridade dos dados.	Alto	Mitigar	1. Implementar tratamento de exceções (try/except) no backend para impedir falhas causadas por payloads inválidos ou maliciosos. 2. Validar estrutura e consistência dos dados recebidos antes do processamento. 3. Planejar autenticação baseada em certificados digitais no broker MQTT para validar dispositivos autorizados. 4. Avaliar implementação futura de assinatura digital das mensagens MQTT para garantir autenticidade dos dados transmitidos.	Luis Sparrapan / Rodrigo Gama	Antes da integração final com o broker MQTT	Em Andamento
TEC-001	Falha no sensor DHT22, retornando	Alto	Mitigar	1. Implementar validação de leitura no firmware: caso o	Luis Sparrapan	Implementação inicial concluída	Em Andamento

	valores inválidos ou nulos devido a falhas físicas, mau contato ou desconexão do componente.			valor retornado seja nulo ou fora da faixa física plausível (-40°C a 80°C), o sistema deve registrar o erro e exibir alerta no display e via MQTT. 2. Realizar verificações periódicas de conexão física do sensor durante os testes de integração. 3. Manter um sensor DHT22 reserva disponível para substituição imediata em caso de defeito confirmado.		antes dos testes de integração	
TEC-002	Temperatura do ambiente monitorado pode sair da faixa segura estabelecida (2°C a 8°C), comprometendo a eficácia das vacinas.	Extremo	Mitigar	1. Implementar lógica de alerta em tempo real no firmware: ao detectar temperatura fora da faixa, acionar imediatamente o LED de alerta e exibir mensagem crítica no display LCD. 2. Publicar mensagem de alerta via MQTT com flag de criticidade para notificação no dashboard. 3. Registrar todos os eventos de violação de faixa no banco de dados com timestamp para rastreabilidade e auditoria.	Ettore Grecco / Luis Sparrapan	Antes da validação final do sistema	Em Andamento
COM-003	O ESP32 pode perder conexão com a rede Wi-Fi devido à instabilidade ou indisponibilidade da rede, interrompendo o monitoramento remoto em tempo real.	Alto	Mitigar	1. Implementar rotina de reconexão automática Wi-Fi no firmware: ao detectar perda de conexão, o sistema tenta se reconectar em intervalos definidos sem interromper a coleta local. 2. Armazenar temporariamente os dados em buffer local (memória do ESP32) durante a	Luis Sparrapan	Antes dos testes de comunicação	Não Iniciado

				indisponibilidade da rede, sincronizando com o servidor ao restabelecer a conexão. 3. Exibir status de conectividade no display LCD para informar o operador local.			
COM-004	Falhas na publicação das mensagens MQTT podem ocorrer devido a erros de conexão ou instabilidade no broker, causando perda de dados no sistema remoto.	Alto	Mitigar	1. Implementar lógica de reenvio (retry): caso a publicação MQTT falhe, o sistema deve armazenar a mensagem localmente e tentar reenviar automaticamente após intervalo configurável. 2. Monitorar o status do broker MQTT e exibir alertas no dashboard em caso de indisponibilidade prolongada. 3. Configurar QoS (Quality of Service) nível 1 no protocolo MQTT para garantir entrega confirmada das mensagens.	Rodrigo Gama / Rafaella Morelli	Antes da integração com o dashboard	Não Iniciado
TEC-005	Defeitos no LED ou no display LCD podem impedir a exibição correta do status do sistema, fazendo com que o operador local não perceba situações críticas.	Alto	Aceitar (Ativo)	1. Alocar tempo de contingência nos testes de hardware para verificação e substituição de componentes defeituosos. 2. Garantir que os alertas críticos (temperatura fora da faixa) sejam redundantes: mesmo com falha do display/LED, o alerta deve ser enviado via MQTT e visível no dashboard web.	Ettore Grecco	Durante os testes de hardware	Não Iniciado
EXT-006	Interrupções no fornecimento de energia podem desligar completamente o sistema,	Médio	Aceitar (Ativo)	1. Alocar reserva de contingência no cronograma para investigação e documentação de ocorrências de queda	Ettore Grecco	Documentação entregue na validação final	Não Iniciado

	paralisando a coleta e transmissão de dados.			de energia durante os testes. 2. Documentar recomendação formal ao operador final do sistema sobre o uso de no-break (UPS) para garantir continuidade do monitoramento em ambientes críticos — esta ação está fora do escopo direto do projeto, mas deve constar como requisito operacional na documentação técnica.			
TEC-007	Erros ou manipulações maliciosas no processamento dos dados podem gerar informações incorretas exibidas no display e enviadas ao servidor, comprometendo a integridade das informações monitoradas.	Baixo	Mitigar	1. Implementar validação de sanidade nos dados processados: verificar se os valores de temperatura e umidade estão dentro de faixas fisicamente plausíveis antes de exibir ou transmitir. 2. Realizar testes unitários da lógica de processamento do firmware com valores de entrada válidos e inválidos, documentando os resultados. 3. Implementar tratamento de exceções (try/except) para impedir falhas causadas por payloads inválidos ou maliciosos recebidos via MQTT.	Luis Sparrapan	Durante a fase de testes unitários	Em Andamento

3. Detalhamento das Estratégias de Resposta

3.1. Estratégias para Ameaças (Riscos Negativos) — Aplicadas ao FlexHealth

Além das estratégias relacionadas à Cybersecurity, o projeto FlexHealth também adota medidas de proteção voltadas à segurança da arquitetura IoT, visando garantir a confidencialidade, integridade e disponibilidade dos dados trafegados entre o ESP32, o broker MQTT, o backend Python e o dashboard web. Entre as ações implementadas estão a utilização de criptografia TLS/SSL na comunicação MQTT, proteção de credenciais sensíveis utilizando variáveis de ambiente (.env), validação de payloads recebidos e planejamento de autenticação para APIs REST.

Prevenir (Evitar): Consiste em eliminar completamente a possibilidade de ocorrência do risco através de mudanças na arquitetura, configuração ou desenvolvimento do sistema.

Aplicação no FlexHealth: Remoção de credenciais hardcoded do código-fonte, utilização de variáveis de ambiente (.env) para armazenamento seguro de informações sensíveis e proteção contra exposição indevida de segredos no repositório GitHub.

Mitigar: Estratégia principal adotada no projeto. Consiste em reduzir a probabilidade de ocorrência do risco e/ou seu impacto a um nível aceitável, por meio de ações preventivas implementadas diretamente no firmware, na comunicação e na arquitetura do sistema.

Aplicação no FlexHealth: Validação de leituras do sensor DHT22, reconexão automática Wi-Fi, reenvio de mensagens MQTT, utilização de criptografia TLS/SSL, proteção de credenciais sensíveis, validação de dados recebidos via MQTT e planejamento de autenticação JWT para a API REST.

Aceitar (Ativo): Adotada para riscos cujo impacto pode ser absorvido pelo projeto ou cuja mitigação total está parcialmente fora do escopo técnico. Envolve a criação de reservas de contingência e de recomendações operacionais documentadas.

Aplicação no FlexHealth: Reserva de tempo para substituição de componentes de interface (LED/display), documentação de requisito operacional de no-break para o risco de queda de energia e monitoramento contínuo dos riscos relacionados à infraestrutura externa e conectividade da rede.

3.2. Nota sobre Riscos Positivos (Oportunidades)

Nesta versão do plano, não foram identificadas oportunidades formais (riscos positivos) passíveis de exploração ativa dentro do escopo do projeto. Caso surjam ao longo do desenvolvimento — como a adoção de bibliotecas que acelerem a integração MQTT, melhorias em mecanismos de autenticação ou ferramentas de monitoramento de segurança — essas oportunidades poderão ser incluídas em revisões futuras deste documento.

4. Monitoramento e Revisão

Este plano será revisado semanalmente nas reuniões de acompanhamento da equipe, em alinhamento com o cronograma definido no Plano de Gerenciamento de Riscos. O campo "Status" será atualizado para refletir o progresso das ações planejadas, podendo assumir os valores: Não Iniciado, Em Andamento, Concluído ou Cancelado.

Novos riscos identificados durante o desenvolvimento serão adicionados a este plano, incluindo riscos relacionados à infraestrutura de rede, comunicação MQTT, autenticação da API e segurança da arquitetura IoT. Riscos existentes poderão ter sua classificação e estratégia reavaliadas conforme a evolução do sistema.

O registro consolidado será mantido no repositório compartilhado no GitHub da equipe, garantindo rastreabilidade, controle de versões e acesso centralizado à documentação do projeto.

Como parte do processo de validação contínua da aplicação, foram realizadas auditorias automatizadas utilizando a plataforma Aikido Security. As análises auxiliaram na mitigação de vulnerabilidades relacionadas à autenticação, criptografia, exposição de credenciais e segurança de dependências externas, contribuindo para a redução de vulnerabilidades críticas, altas, médias e baixas identificadas durante o desenvolvimento do sistema.
